

TurkSquare

Teknik Handover ve Konuşma Bağlam Belgesi

Azure AI veya yeni bir teknik asistana devredilmek üzere hazırlanmış, güvenli ve yapılandırılmış proje özeti

Alan	Değer
Belge tarihi	4 Ağustos 2026
Kapsam	Başlangıçtan bugüne mimari kararlar, uygulama geliştirmeleri, altyapı, sorunlar, çözümler ve açık işler
Gizlilik	Gizli. Token, parola, API anahtarı, tam hesap kimliği ve hassas kişisel veri redakte edilmiştir.
Amaç	Yeni Azure AI / Android Studio asistanının projeyi yeniden keşfetmeden güvenli biçimde devralması

Önemli not

Bu PDF ham sohbet dökümünün otomatik ve kelimesi kelimesine exportu değildir. Tekrarlayan ara mesajlar, ekran görüntüsü metinleri ve gizli bilgiler ayıklandı; bunun yerine tüm önemli kararları, komut sonuçlarını, hataları, çözümleri, mevcut durumu ve bekleyen işleri kapsayan ayrıntılı, güvenli bir yeniden yapılandırılmış context log hazırlanmıştır.

1. Yönetici özeti

TurkSquare, Amerika'daki Türk topluluğu için mobil topluluk, Akış, Çarşı, doğrulanmış üye, forum ve özel mesajlaşma ürünüdür. Uygulama Flutter istemcisi ile, AWS üzerinde ayrıştırılmış servisler ve Cloudflare edge güvenliğiyle geliştirilmektedir. Ana hedef; kullanıcı kimliği, topluluk içeriği, doğrulama ve dosyaları birbirinden ayıran, ölçeklenebilir ve denetlenebilir bir üretim mimarisidir.

Şu anda en olgun alan Identity / oturum altyapısı, AWS çok hesaplı Terraform temeli, GitHub OIDC CI/CD zinciri, Resend tabanlı e-posta akışı ve Gatework yönetim merkezi temelidir. Uygulama tarafında giriş, kayıt, OTP, onboarding ve Akış tasarımının önemli bölümü vardır; ancak Akış, Story, Çarşı, Forum, Matrix mesajlaşma ve yönetim ekranlarının çoğu gerçek domain API'leriyle uçtan uca tamamlanmamıştır.

Alan	Gerçek durum	Düzy
AWS organizasyon ve Terraform state	Çok hesaplı yapı, uzaktan state bucketi, lock tablosu, KMS ve GitHub OIDC rolleri kuruldu.	Çalışıyor / gözden geçirilmeli
Identity	ECS, RDS, KMS imzalı token, kayıt, OTP, e-posta, çıkış, onboarding API temeli mevcut. Son deploy engeli kalıcı olarak düzeltildi.	Çalışıyor / cihaz E2E doğrulaması gerekli
Community	Hesap, Terraform ve servis temeli var; Akış/Story ekranında halen mock/eksik davranışlar görülebilir.	Kısmi
Gatework	Next.js servis, Cloudflare Tunnel/Access ve admin rol temeli kuruldu. Access politikası ve tam login E2E tekrar doğrulanmalı.	Kısmi
Forum / Matrix / Stripe / ihale	Mimari kararlar alındı. Canlı ürün işlevi henüz kurulmadı veya bilinçli olarak ertelendi.	Planlandı

2. Bu belgeyi Azure AI'ya nasıl kullanmalı

- Bu PDF'yi tek başına kaynak gerçekliği kabul etmemeli; önce repo, Terraform state, GitHub Actions son çalışmaları ve AWS konsol durumları read-only doğrulanmalıdır.
- Azure AI'ya ilk görev olarak 'mevcut mimariyi ve açık işleri doğruyla, doğrudan altyapı değişikliği yapma' verilmelidir.
- Gizli değerler bu belgede yer almaz. Azure AI'dan token, parola, API key veya kullanıcı belgesi istememesi; Secrets Manager / GitHub Secrets referanslarını yalnızca isim olarak kullanması istenmelidir.
- İlk geliştirme paketi olarak Community gerçek API + Akış/Story, ardından Matrix DM ve Flarum önerilir. Mevcut altyapıyı Azure'a taşımaya hemen başlanmamalıdır.

3. Ürün hedefi ve kapsam

TurkSquare; üyelerin kendi eyalet/şehir bağlamlarında Akış ve Çarşı içeriklerini gördüğü, ancak diğer eyaletlerden içeriği de dengeli biçimde alabildiği bir topluluk uygulamasıdır. Yeni kullanıcı ilk girişte boş ama yönlendirici deneyim alır; ilişkileri, story'leri veya ilanları yoksa sahte içerik gösterilmez.

Ürün alanı	Karar / hedef
Ana Sayfa	Üyeye, onboarding konumuna ve ilgi alanına göre şekillenir; Günün Topluluk Nabzı gerçek toplulaştırılmış veriden gelir.
Akış	Senin İçin, Yakınındakiler ve Takip Ettiklerin; cursor sayfalama, sıralama, gerçek etkileşim sayıları.
Story	Yalnızca yetkili ilişkiler, resmî sistem hesapları ve izinli yakın çevre; 6/12/24 saat TTL; tam ekran izleme, kalp, yanıt, highlight.
Çarşı	Kullanıcı aktif ilanı paylaşabilir; ihale doğrulanmış satıcılarla sınırlıdır.
Forum	Self-hosted Flarum, TurkSquare OIDC ile tek giriş.
Mesajlar	Self-hosted Matrix Synapse, yalnızca 1:1 DM, federasyon ve public room yok.
Doğrulama	İleride Stripe Identity; TurkSquare kimlik görseli, selfie veya kimlik numarası saklamaz.

4. Kronolojik çalışma kaydı

Aşağıdaki kayıt, sohbet boyunca alınan önemli kararların ve yapılan çalışmaların sıralı teknik özetidir. Tekrarlayan ekran yönlendirmeleri yerine problem, neden ve sonuç kaydedilmiştir.

A. İlk mobil tasarım ve Akış kapsamı

- Kullanıcı, verilen HTML/Figma tasarımına birebir yakın Akış görünümü istedi; yalnızca Akış sayfasına dokunulması istenerek başlandı.
- Kullanıcı, mevcut görünümün örnekten uzak olduğunu belirtti. Tasarım; üst topluluk başlığı, filtre sekmeleri, yatay Story şeridi, paylaşım bestecisi, post kartları ve alt menü şeklinde yeniden ele alındı.
- Daha sonra tasarımın tek başına yeterli olmadığı kabul edilerek Akış için üretim veri ve API planı çıkarıldı.

B. Akış üretim planı

- REST + PostgreSQL/PostGIS + S3/R2 yaklaşımı benimsendi. FeedRepository, interaction, poll, story ve location sözleşmeleri tarif edildi.
- Akış modları: for_you, nearby, following. İstemci lokal filtreleme yapmayacak; cursor ve seçili mod tutacak.
- Post etkileşimleri sunucu gerçeği, optimistic UI ile geri alma; tam koordinat hiçbir kartta gösterilmeyecek.

C. Güvenli kimlik ve veri altyapısı

- Öncelik e-posta/parola, doğrulama, token yenileme ve güvenli çıkışa verildi.
- Kimlik, community, verification vault, backup/security/log için AWS Organizations altında ayrı hesaplar oluşturuldu.
- Evrak doğrulama mimarisi hazırlandı: ayrı vault, private object storage, lifecycle, audit, KMS, işçi kuyrukları. İlk sürümde harici KYC yoktu; sonra Stripe Identity kararı alındı.

D. GitHub OIDC ve Terraform bootstrap

- Management hesabında Terraform remote state bucketi, DynamoDB lock tablosu ve KMS anahtarı kuruldu.
- GitHub Actions için kalıcı access key yerine OIDC trust ve plan/apply rolleri StackSet ile iş hesaplarına dağıtıldı.
- Service-managed StackSet / Organizations access, yanlış YAML indentation, eksik principal, yanlış OIDC subject ve instance güncelleme hataları adım adım giderildi.

E. E-posta teslimatı

- AWS SES sandbox erişimi başta reddedildi. SES temeli silinmeden, işlem e-postaları için Resend'e geçildi.
- notify.turksquare.com altında DNS, DKIM, SPF ve MX doğrulandı. SQS -> Lambda relay -> Resend zinciri doğrudan test edilerek teslimat doğrulandı.
- SQS testlerinin bazıları batch/event biçimi nedeniyle yanıltıcıydı; Lambda doğrudan testte teslimat anlık görüldü.

F. Identity uygulaması ve giriş deneyimi

- Kayıt, e-posta doğrulama, OTP, token/refresh, logout ve onboarding akışları geliştirildi. Aktivasyon magic-link yaklaşımı 59 saniyelik kod yaklaşımına çevrildi.

- Figma ilhamlı e-posta-önce giriş eklendi: kayıtlı e-posta aynı ekranda şifre adımını açar, yeni e-posta kayıt formuna önceden doldurulmuş gider.
- E-posta durum endpointi /v1/auth/email/status eklendi; hesap keşfi riski rate limit, normalize yanıt ve audit ile azaltılacak şekilde tasarlandı.
- Kullanıcı tarafından görülen 404, TLS/bağlantı, tekrar kayıt, e-posta kodu ve onboarding hataları incelendi; bazıları kod/deploy ile düzeltildi, E2E regresyon doğrulaması halen gereklidir.

G. Gatework yönetim merkezi

- Next.js 15 + TypeScript, shadcn/ui/Tailwind, TanStack ve tRPC BFF planlandı. Ayrı hesap açmadan Community hesabında izole servis olarak konumlandırıldı.
- Cloudflare Tunnel sidecar + Cloudflare Access + mevcut TurkSquare Identity ile iki katmanlı erişim kurgulandı.
- Cloudflare Access MFA / App Launcher kurulumunda politika, authenticator ve ilk kullanıcı yetkilendirmesi sorunları çıktı. TOTP/Biyometrik ayarları yapıldı; Access uygulamasının son kullanıcı E2E erişimi ayrıca kontrol edilmelidir.

H. Son Identity deploy kök neden çözümü

- Gatework bootstrap owner oluşturulduktan sonra GATEWORK_BOOTSTRAP_OWNER_EMAIL secretı güvenlik için kaldırılmıştı.
- Identity ECS task definition bu secretı kalıcı zorunlu secret olarak istemeye devam ettiği için task start aşamasında 'retrieved secret did not contain json key' hatası veriyordu.
- Bu bağımlılık kaldırıldı, environment örneği ve bootstrap dokümanları güncellendi. Build ve Terraform apply başarılı oldu; ardından Identity deploy tekrar başarıyla tamamlandı.

5. Mevcut teknik mimari

Aşağıdaki mimari hedef mimari ile fiilen görülmüş bileşenleri birlikte gösterir. 'Planlandı' ifadeleri çalışır üretim özelliği anlamına gelmez.

5.1 Hesap ve sorumluluk ayrımı

Sınır	Sorumluluk	Durum
Management	Organizations, Terraform state, merkezi bootstrap ve çapraz hesap ilkeleri.	Kuruldu
Identity	Kullanıcı hesabı, parola hash, refresh token ailesi, OTP, access token imzalama, OIDC hedefi.	Kuruldu / geliştiriliyor
Community	Akış, ilişkiler, Çarşı, PostGIS, medya, Gatework, ileride Matrix/Flarum gatewayleri.	Temel kuruldu
Verification Vault	Doğrulama oturum referansı/audit ve ileride Stripe Identity webhook işlemleri.	Temel / Stripe kapalı
Backup-Security-Log	Yedekleme, güvenlik logları ve felaket kurtarma için ayrılmış sınır.	Hedef/temel

5.2 Ağ, erişim ve çalışma prensibi

- RDS doğrudan internete açık olmamalı; servisler private ağ / güvenlik gruplarıyla erişir.
- NAT Gateway kullanılmıyor. Bu bilinçli bir maliyet ve yüzey alanı tercihidir. AWS servis erişimleri için VPC endpointleri ve container image çekimi için ECR endpointleri tasarlanmıştır.
- Cloudflare Access ve Tunnel Gatework originini inbound public erişim olmadan korur. Cloudflare Tunnel kesilirse Gatework erişilemez; Community API etkilenmemelidir.
- Mobil API uçları public ALB/WAF/ACM arkasında olabilir; private veri katmanları public olmaz.
- Secret değerleri mobil uygulama, source code veya GitHub loglarına konulmaz; AWS Secrets Manager/KMS üzerinden sağlanır.

5.3 Ana teknoloji eşlemesi

Katman	Seçilen teknoloji	Not
Mobil	Flutter	Android/iOS/web debug sırasında geliştirildi; auth ve onboarding ekranları aktif geliştirildi.
Kimlik	Node/TypeScript Identity service, PostgreSQL, KMS imzalı JWT	OIDC provider olma yönünde genişletiliyor.
Topluluk	REST API, PostgreSQL/PostGIS, Redis, S3 uyumlu private medya	Gerçek Akış/Story API tamamlanacak.
E-posta	Resend + SQS/Lambda relay	SES altyapısı korunuyor ancak üretim gönderimi Resend ile.
Yönetim	Next.js 15, shadcn/ui, Tailwind v4, tRPC BFF	Gatework, Cloudflare Access/Tunnel arkasında.
Forum	Flarum + MySQL	Planlandı; OIDC-only giriş.

Katman	Seçilen teknoloji	Not
DM	Matrix Synapse	Planlandı; sadece private 1:1 room.
Ses	LiveKit self-hosted	Sonraki faz.
Kimlik doğrulama	Stripe Identity	Maliyet nedeniyle şu an kapalı; ham evrak TurkSquare'de tutulmaz.

6. Kimlik, oturum ve onboarding

Kimlik sistemi mobil ürünün güvenlik önceliğidir. Giriş eksik veya doğrulanmamış hesapların community yetkilerine erişmemesi gerekir.

6.1 Mevcut hedef akış

Aşama	Davranış
1. E-posta	Kullanıcı sadece e-posta girer. Geçersiz format alan altında gösterilir.
2. E-posta durumu	Rate-limited email/status çağırısı ile kayıtlı olup olmadığı bulunur.
3a. Kayıtlı kullanıcı	Aynı ekranda animasyonlu şifre alanı çıkar; e-posta kilitletir veya değiştirme seçeneği bulunur.
3b. Yeni kullanıcı	Register ekranına e-posta önceden doldurulmuş gider.
4. Kayıt	Ad, e-posta, güçlü parola, koşullar onayı; tekrar kayıt ve zayıf parola sunucuda da reddedilir.
5. OTP	59 saniye geçerli kod e-posta ile gelir. Başarısız/sonlanmış/resend durumları kullanıcıya anlaşılır biçimde bildirilir.
6. Onboarding	Yerel bağlam ve ilgi alanları; tamamlanmadan kişiselleştirilmiş ana deneyim açılmaz.
7. Oturum	Kısa ömürlü access token, dönen refresh token ailesi, sunucu iptali; profil üzerinden güvenli çıkış.

6.2 Önemli kurallar

- E-posta doğrulaması yapılmamış hesap tam uygulama erişimi almamalıdır. Bu daha önce görülen açık için regresyon testi zorunludur.
- Password field kopyalama/paste politikası platforma göre değerlendirilmeli; password manager desteğini engellemek güvenliği azaltabileceği için tamamen kapatmak yerine görünürlük, clipboard ve autofill davranışı dikkatle test edilmelidir.
- Google, Apple, telefon ve passkey giriş düğmeleri canlı flow yoksa sahte giriş başlatmamalı; gizlenmeli veya açıkça 'yakında' mesajı göstermelidir.
- E-posta durum endpointi kullanıcı keşfi riski taşır. Çok düşük kullanıcı/IP rate limit, sabit gecikme/normalize hata, gözlem ve abuse politikası uygulanmalıdır.
- E-posta/OTP başarısında account enumeration ve teslimat ayrıntısı loglanırken mesaj içeriği veya kod loglanmamalıdır.

6.3 Onboarding ve konum

- Kullanıcı kayıt olurken mevcut konum izin verirse eyalet/şehir bağlamına adapte edilir. Kullanıcı daha sonra profilden güncelleyebilir; her girişte eyalet seçmeye zorlanmaz.
- Google Maps/Places entegrasyonu ileri aşama için abstraction halinde hazırlanmalı; şu anda API key etkinleştirilmemiştir.
- İleride tek satır bölge araması, Places autocomplete ve mevcut konum seçimi kullanılır. Tam koordinat feed kartlarına veya genel analitiğe hiç sızmaz.
- Onboarding UI yenilendi: ilgi alanları ikonlu, yumuşak kart yapısı; 'en çok ne için kullanacaksınız' seçeneği kaldırıldı. Kullanıcının gördüğü 'onboarding bilgileri geçersiz / kaydedilemedi' hatası için API şeması ve auth token E2E doğrulaması gereklidir.

7. Community, Akış ve Story planı

Uygulamada görünen Akış arayüzü ilerlemiş olsa da, gerçek API ile eksiksiz bağlanmış bir sosyal graf ve içerik sistemi henüz tamamlanmadı. Öncelik, mock davranışları tek tek gerçek repository/API sözleşmelerine geçirmek olmalıdır.

7.1 Akış API sözleşmesi

Bileşen	Gerekli davranış
GET /community/feed	mode=for_you nearby following, cursor pagination, stable sıralama, yetkilendirme ve blok listesi filtresi.
Post	Standart, anket, Çarşı ilanı referansı; visibility, yorum politikası, yaklaşık konum.
Interaction	Like/save/share/comment sunucu kaynaklı sayılar; isLiked/isSaved görüntüleyici durumu; optimistic rollback.
Poll	2-4 seçenek, tekli/çoklu oy, bitiş zamanı, bir kullanıcı için tek atomik vote kaydı.
Media	Galeriden/kameradan seçilen dosyalar, MIME/size/duration validation, presign upload, tarama/EXIF temizleme.
Location	Action ile izin, yaklaşık şehir/mahalle, metin/mekân arama. Ham GPS yalnızca backend nearby sorguları için.

7.2 Konuma dayalı sıralama

- Kullanıcının yerleşik eyaleti/şehri mevcut sıralamanın güçlü bir sinyaldir. Örneğin New Jersey kullanıcısı NJ içeriğini daha sık görür; diğer eyalet içerikleri de kontrollü aralıklarla karışır.
- Nearby yalnızca kullanıcı izin verirse yaklaşık konum veya hücre/yarıçap üzerinden çalışır. Tam GPS feed response ve UI'dan çıkarılır.
- Sıralama; güncellik, ilişki (arkadaş/takip), ilgi alanı, eyalet/şehir uyumu, etkileşim kalite sinyali, moderasyon ve block listeyi birleştirir.
- Yeni postlar eş zamanlı akışta yukarıdan düşebilir; pagination bütünlüğü için stable cursor/snapshot sınırı veya explicit 'yeni postlar' bandı kullanılmalıdır.
- Yeni üyede gerçek içerik yoksa boş durum: şehir/ilgi alanını tamamla, ilk paylaşım yap, üyeleri takip et. Mock kişi/post gösterilmez.

7.3 Story kapsamı

Özellik	Karar
Şerit	Yatay cursor pagination; Story Ekle ilk kart; 1.000+ ilişkiyi destekler; gereksiz filtre kaldırılır.
Erişim	Arkadaşlar/takip edilenler, resmî TurkSquare sistem hesapları ve izinli yakın çevre; isteğe bağlı public.
TTL	6h, 12h veya 24h; server expiration; süresi dolan/uygunsuz story dönmez.
Viewer	Tam ekran sıralı foto/video, ilerleme, video pause/resume, idempotent view ve heart.
Yanıt	Story ID ve preview referansı ile Matrix DM'e gider; mesaj içeriği aynı ortamda görülür.
Highlight	Kullanıcı seçtiği süreli story'leri profilinde kalıcı highlight olarak tutabilir.
Editör	Kamera/galeri, metin, sticker/ikon, filtre/effect. GPUImage Android/iOS değerlendirilmiş; native/platform uyumluluğu ayrıca doğrulanmalı.

7.4 Story ve Akış için kabul testleri

- Yetkisiz veya süresi geçmiş story hiçbir endpointten gelmez.
- Her view yalnızca bir kez sayılır; heart idempotent olur.
- Yüklemeler tamamlanmadan post/story yayınlanmaz; yeniden deneme ve kullanıcıya hata durumu vardır.
- Yaklaşık konum dışında tam konum veya EXIF GPS response/log içine sızmaz.
- Cursor, yeniden açma ve eşzamanlı yeni postlarda tekrar/atlama yapmaz.
- Raporlanan/engellenen hesapların içerikleri tüm feed modlarından çıkarılır.

8. Çarşı, ihale, Forum, Matrix ve doğrulama

Bu alanlar için doğru mimari kararlar alındı fakat canlı kullanıcı özellikleri olarak tamamlanmadılar.

8.1 Çarşı ve canlı ihale

- 'Fiyat Ekle' yerine kullanıcının sahip olduğu aktif Çarşı ilanını feed postuna bağlama seçildi. Feed fiyat/sahiplik düzenlemez.
- İhale sadece owner olduğu aktif ilan üzerinde ve identityVerified + auctionSellerEligible kullanıcı tarafından açılır.
- İhale formu: ilan, başlangıç fiyatı, minimum artış, başlangıç/bitiş zamanı, kurallar.
- Teklifler sunucu zamanı ile atomik yazılır; min artış, kapanış, satıcının kendi ilanına teklif vermesi ve yarış koşulları sunucuda denetlenir.
- İlk sürüm bağlayıcı ödeme içermez. Kapanışta kazanan/satıcı arasında backend tarafından private Matrix DM açılır. Escrow, depozito, iade ve uyuşmazlık sonraki fazdır.

8.2 Flarum

- Flarum Community hesabında ayrı container, ayrı MySQL. Bağımsız register/parola ekranı olmayacak; tek giriş TurkSquare OIDC.
- İlk kapsam: kategori, konu, yanıt, arama, rapor, moderasyon. Ana Sayfa trend tartışmaları Flarum'dan backend gateway aracılığıyla gelir.

- Rozet/itibar/ağır plugin kullanımı ikinci forum aşamasında değerlendirilir.

8.3 Matrix sadece private DM

- Self-hosted Matrix Synapse; federasyon başlangıçta kapalı, public room/directory/listing yok.
- Kullanıcılar uygulamada server/channel/room UI görmez. Matrix yalnızca WhatsApp/Instagram benzeri DM altyapısıdır.
- DM room sadece backend tarafından kullanıcı A-B veya ihale satıcı-kazanan için private_chat, visibility=private, is_direct=true ile açılır.
- Matrix ana TurkSquare parolasını almaz. OIDC/short-lived delegated erişim veya backend-issued Matrix credential tasarlanmalı.
- Gatework DM içeriğini varsayılan olarak görmez; yalnızca raporlanan içerik ve minimum olay metadatası moderasyon akışına alınabilir.

8.4 Stripe Identity

- Stripe Identity, verified badge ve auction seller eligibility için seçildi; şu an maliyet nedeniyle kapalı. Kullanıcı kimlik belgesi, selfie veya ID numarası TurkSquare DB/S3'e alınmaz.
- Sadece verification session reference, sonuç, politika sürümü, zaman damgası ve audit saklanır.
- Webhook imzası doğrulanır, idempotent işlenir; 30 gün içinde redaction ve silme talebinde ek redaction planlanır.
- Gateworkte yalnızca sonuç/audit görünür; ham Stripe dosyası, selfie ve belge asla görünmez.

9. E-posta ve bildirim altyapısı

SES üretim erişimi ilk aşamada onaylanmadığı için sistemin işlem e-postaları Resend'e taşındı. AWS tabanlı relay/gözlem yapısı korunarak sağlayıcı değişimi çevik tutuldu.

Bileşen	Karar / gözlem
Gönderen domain	notify.turksquare.com üzerinde Resend domain doğrulaması; DKIM, SPF ve MX kayıtları Cloudflare DNS'te.
Relay	SQS -> Lambda -> Resend. Kuyruk tetikleme ilk testlerde batch/event biçimi nedeniyle yanıtıcıydı; Lambda doğrudan çağrısında e-posta anlık teslim edildi.
İşlem e-postaları	OTP, doğrulama, parola sıfırlama, güvenlik bildirimleri ve uygulama içi operasyon mesajları.
Güvenlik	Resend API anahtarları yalnızca Secrets Manager; loglarda OTP, token, tam alıcı listesi veya API key tutulmaz.
SES	SES kaynakları/planı silinmedi. Sandbox/production erişim konusu gelecekte yeniden değerlendirilebilir.

10. Gatework güvenli yönetim merkezi

Gatework, normal kullanıcı uygulamasının admin arayüzü değildir. Yetkili ekip için ayrı güvenlik katmanları bulunan bir operasyon konsoludur.

10.1 Hedef güvenlik modeli

- Adres: gatework.turksquare.com; doğrudan api./admin path yaklaşımı kullanılmaz.
- Layer 1: Cloudflare Access - allow-list üyelik ve MFA, bypass policy yok.
- Layer 2: TurkSquare Identity oturumu + server-side Gatework role doğrulaması. Token claim tek başına yetki değildir.
- Cloudflare Tunnel, Gatework ECS görevinde sidecar olarak outbound-only çalışır; inbound origin açılmaz, NAT eklenmez.
- High-risk operations: rol değişimi, kalıcı engel, export, resmî hesap oluşturma/kapatma, verification status değişimi için son 5 dakika step-up/passkey/MFA.
- Oturum: 30 dakika idle, 8 saat absolute hedefi; `Cache-Control: no-store`, HttpOnly/Secure cookie, CSRF, CSP, HSTS, frame koruması.
- Her mutation: idempotency key, reason, request ID, actor role, redacted diff ve Cloudflare request ID ile audit. Parola/token/belge/DM/tam GPS auditlenmez.

10.2 Menü tasarımı

Menü	İlk görev	Durum
Komuta Merkezi	Servis sağlığı, kuyruklar, hata oranı, kritik işlemler, moderasyon/SOS sayaçları.	Temel plan
İçerik Stüdyosu	Resmî sistem hesabı ile post/story/kampanya taslak ve planlı yayın.	Öncelikli sonraki
Üyeler	Arama, profil durumu, askıya alma, oturum iptali, support notes.	Plan

Menü	İlk görev	Durum
Moderasyon	Post/comment/story/listing/user/media rapor kuyrukları.	Plan
Çarşı ve ihaleler	İlan ve ihale inceleme, ihtilaf görünümü.	Plan
Mesajlar / Forum	Sadece Matrix/Flarum canlı olduğunda rapor/moderasyon yönetimi.	Ertelendi
Güvenlik/SOS	Sürelî tam GPS erişimi, olay/notification durumu.	Ertelendi
Doğrulama	Stripe sonuç/audit özeti, ham doküman yok.	Stripe açılınca

Gatewaykte hazırlanmamış alanlar sahte veri ile 'çalışıyor' gibi görünmemelidir. Kullanıcı yalnızca durum kartı görmelidir.

11. DevOps, IaC ve olay kayıtları

11.1 Bilinen altyapı bileşenleri

Bileşen	Durum / not
Terraform state	Management hesabında encrypted S3 bucket, DynamoDB lock ve KMS ile oluşturuldu.
GitHub OIDC	Plan/apply rolleri StackSet ile dört iş hesabına dağıtıldı; OIDC trust kapsamı ve state access rolleri düzeltildi.
ECR / ECS	Servis image build/deploy zinciri; immutable image kullanımı ve role image inspect erişimi ile ilgili hatalar düzeltildi.
RDS	Identity ve Community için ayrı Postgres; Community tarafında PostGIS hedefleniyor.
CloudWatch / WAF / ALB	Maliyet ekranında aktif görünür. Log retention/alarmalar ayrı audit gerektirir.
VPC	NAT Gateway yok. VPC endpointleriyle AWS içi servis erişimi hedefleniyor.
Secrets Manager	Identity service config ve Gatework config için kullanılıyor. Bootstrap secretlarının kalıcı task contractına girmemesi kuralı eklendi.

11.2 Önemli sorunlar ve kalıcı dersler

Sorun	Kök neden	Kalıcı çözüm / ders
StackSet/Organizations erişimi	Yanlış servis principal, service-managed ayarları, hatalı parametre/kapsam.	Operations statüsü beklenmeli; instance güncelleme tek tek ve mevcut state kontrol edilerek yapılmalı.
OIDC AssumeRoleWith WebIdentity	GitHub subject trust kapsamı ve rol dağıtımı uyumsuzdu.	OIDC condition claimleri branch/environment/repo ile net tutulmalı; plan/apply rolleri için unit-style policy test gerekir.
Terraform state role policy	YAML indentation / invalid principal ve apply role henüz oluşmadan güven ilişkisi yazılması.	Template validation + rolün varlığını kontrol + staged deploy uygulanmalı.
Identity deploy task start	Kaldırılmış bootstrap secretı task definition'da mandatory JSON key olarak kalmıştı.	One-shot bootstrap değerleri production runtime contractından ayrıldı. Bu düzenleme deploy başarıyla doğrulandı.
Gatework deploy	Secret/role/runtime ve Cloudflare config sıralaması; eksik detaylar nedeniyle yineleyen workflow fail.	Preflight validator, environment contract test ve deploy readiness checklist zorunlu olmalı.
Cloudflare Access	App Launcher/Access policy/MFA/authenticator ilişkisi ve kullanıcı allow-list ayarı belirsizdi.	Önce identity provider, MFA method, Access policy, application association ve test user sırası doğrulanmalı.
E-posta relay	SQS event ile Lambda direct invoke farkı ve test event şeması.	Queue payload schema contract test + DLQ + delivery event observability eklenmeli.

11.3 Referans commitler

Commit	Özet
4b8b324	Gateway Tailwind stillerini compile edecek düzeltme.
df8dec1	Redeploy sırasında immutable image kullanımı.
676aefe	Deploy rollerinin release image inspect yetkisi.
d103df0	Identity deploy'u tek seferlik Gateway bootstrap owner secretından ayıran düzeltme.

Not: Bu liste konuşma sırasında özellikle doğrulanan başlıca commitleri içerir; eksiksiz Git history yerine geçmez. Yeni asistan git log ve pull requestleri read-only incelemelidir.

12. Azure değerlendirmesi ve hibrit bulut kararı

Mevcut sistem AWS ekosistemine anlamlı derecede bağlanmıştır: KMS imzalı JWT, ECS, ECR, RDS, SQS, Lambda, Secrets Manager, CloudWatch, ALB/WAF/ACM ve S3. Bu nedenle tam Azure migrasyonu bu aşamada ürün hızını düşürür ve kimlik/transaction veri riskini artırır.

12.1 Tam Azure migration

AWS	Azure karşılığı	Geçiş değerlendirmesi
ECS	Azure Container Apps veya AKS	Container/runtime ve network model tekrar kurulmalı.
ECR	Azure Container Registry	CI deploy ve image policy dönüşür.
RDS PostgreSQL	Azure Database for PostgreSQL Flexible Server + PostGIS	Veri, index, HA, backup ve connection yönetimi yeniden test edilir.
Secrets Manager/KMS/IAM	Key Vault + Managed Identity	JWT signing ve key policy daha kritik migration kalemidir.
SQS	Azure Service Bus	Queue ordering, retry, DLQ, dedup ve idempotency yeniden doğrulanır.
Lambda	Azure Functions / Container Apps Jobs	Event ve observability sözleşmeleri değişir.
ALB/WAF/ACM	Front Door Premium/WAF + Key Vault	Public ingress, TLS, domain cutover dikkatle yapılır.

Tahmin: kapsamlı, güvenli bir full migration; deneyimli ekipte yaklaşık 8-12 hafta, küçük ekipte 12-16 haftadır. Bu tahmin sadece engineering çalışmasıdır; compliance, data migration rehearsal, mobile cutover ve incident readiness süreleri eklenebilir.

12.2 Önerilen hibrit model

- Şimdi AWS'te transactional core kalsın: Identity, Community/PostGIS, Vault, media, SQS, e-posta relay ve Gateway runtime.
- Azure daha sonra izole iş yükleri için değerlendirilsin: kimliksiz/toplulaştırılmış analytics, ayrı LLM/RAG/AI işleme, ikinci bağımsız DR drill veya özel veri işleme laboratuvarı.

- Tek bir transaction veya kullanıcı domainini iki buluta bölmeyin. Örneğin auth access/refresh token veya community primary DB hem AWS hem Azure arasında aktif-aktif çalışmamalıdır.
- Cloudflare edge güvenliği iki bulutun önünde kalabilir. SSO, audit ve tenant separation bulutlar arası minimum referans ile yapılmalıdır.
- Hibrit model 'daha güvenli' olduğu için değil; bağımsız blast radius, vendor risk ve ayrı analitik/AI iş yükü için kullanılır. Dağıtık kimlik, ağ ve veri senkronizasyonu yanlış uygulanırsa güvenlik azalır.

12.3 Azure kaynakları

- Azure Container Apps + Front Door private connectivity:
<https://learn.microsoft.com/en-us/azure/container-apps/front-door-custom-virtual-network-private-link>
- Azure PostgreSQL HA: <https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/concepts-high-availability>
- Azure PostgreSQL backup/restore:
<https://learn.microsoft.com/en-us/azure/postgresql/backup-restore/concepts-backup-restore>
- Managed identity: <https://learn.microsoft.com/en-us/azure/container-apps/managed-identity>
- Container Apps secrets: <https://learn.microsoft.com/en-us/azure/container-apps/manage-secrets>
- Service Bus duplicate detection: <https://learn.microsoft.com/en-us/azure/service-bus-messaging/duplicate-detection>
- PostgreSQL extensions/PostGIS:
<https://learn.microsoft.com/en-us/azure/postgresql/extensions/concepts-extensions-versions>

13. Güvenlik kontrol listesi

Yeni teknik asistan bu listeyi değişiklikten önce doğrulamalıdır.

Kontrol	Hedef	Şu anki değerlendirme
Secrets	Secret yalnızca Secrets Manager/KMS; code/log/CI output yok.	Tasarım mevcut, her yeni deploy için tarama şart.
Least privilege	Service, plan, apply ve state rolleri ayrık; deploy rolü yalnız gerekli eylemleri alır.	Kuruldu, policy regression testi eksik.
Network	RDS private; Gatework origin private/Tunnel; NAT yok; endpointler gereklikçe.	Hedef/temel mevcut, SG/route audit gerekli.
Auth	Email verified gate, OTP 59s, refresh family revocation, logout.	Kod mevcut; gerçek cihaz E2E test gerekli.
Rate limit	Login, register, email status, OTP, post, comment, vote, story reply, upload.	Kısmen tasarlanmış; merkezi enforce/doğrulama gerekli.
Audit	Admin mutationlarda reason/idempotency/request ID/redacted diff.	Gatework temeli, domain integration bekliyor.
PII	Full GPS, document, selfie, token, DM içerikleri yönetim paneli/audit/log dışında.	Politika net; implementation review gerekli.
Backups/DR	Encrypted backup, ayrı hesap/bölge, restore test, RPO/RTO drill.	Planlandı; test kanıtı gerekli.
Cloudflare Access	Allowed users + MFA, no bypass, application policy association.	Konfigürasyon yapıldı; final E2E test gerekli.

14. Mevcut açık işler - öncelik sırası

Bu sıralama, özellik yığmak yerine mevcut ürünün gerçek ve güvenli çalışmasını öncelemektedir.

P0 - Üretim güveni ve regresyon

- Identity servisinin public health endpoint, login/register/OTP/email verify/onboarding/logout akışlarını gerçek Android ve iOS cihazında uçtan uca test et.
- API base URL, TLS/ACM, Cloudflare DNS/proxy ve CORS/redirect ayarlarını tekrarlanabilir smoke test ile doğrula.
- Onboarding kaydetme ve 'onboarding bilgileri geçersiz' hatasını schema, token, endpoint ve DB migration seviyesinde teşhis et/düzeltil.
- Gatework Access Application association, allow list, MFA, app login ve TurkSquare admin role katmanını E2E test et.
- GitHub Actions için preflight: secret key presence, Terraform validate/plan, OIDC trust policy check, ECR image existence, deploy config schema test ekle.

P1 - Community gerçek API

- Community service health + database schema + core profile/relationship endpointlerini doğrula.
- Cursor feed for _you/nearby/following, gerçek post/interaction/comment/save/share API; Flutter repository bağlama.

- Yeni kullanıcı boş durumları, state/interest ranking ve real-time new post davranışını geliştir.
- Media presign/upload pipeline, EXIF temizleme, retry ve moderation contracts.

P2 - Story

- Story create/view/reply/heart/TTL/end-to-end; horizontal cursor strip; highlight model.
- Camera/gallery ve effect editor research/prototype; GPUImage native wrapper kararını platform testinden sonra ver.

P3 - Gatework içerik stüdyosu

- Resmî sistem hesabını Identity login yapamayan system account olarak oluştur.
- Gatework üzerinden first official post/story publication, scheduling, region/visibility ve immutable audit.

P4 - Forum / Matrix

- Flarum OIDC-only, ayrı MySQL/container; forum gateway/feed trend integration.
- Matrix Synapse DM-only, federation off, backend room provision, user block/report, app messaging screen.

P5 - Stripe / auction

- Stripe Identity canlı erişim/maliyet onayı alındığında verification service/webhook/redaction/audit.
- Ardından auction eligibility, atomic bids, closure-to-Matrix DM.

15. Azure AI için başlangıç talimatı

Yeni asistana şu talimat verilebilir:

"Bu belge TurkSquare için güvenli handover kayıdır. Önce C:\AmericaHub\tr-sq2026-bootstrap reposunu, GitHub Actions son çalışmaları, Terraform state ve AWS servis health durumlarını read-only incele. Belgedeki çalışıyor ifadelerini kanıtla, sıradaki P0 maddelerini raporla. Gizli değer isteme veya yazma; Secrets Manager/GitHub Secrets sadece referans isimleriyle ele al. Transactional core'u AWS'te koru; Azure kullanımı için önce izole analytics/AI iş yükü önerisi hazırla. Her değişiklikten önce etkisini, geri dönüşünü ve test planını açıkla."

16. Redaksiyon ve sınırlamalar

- Bu PDF'de kullanıcı parolaları, OTP kodları, Resend/Stripe/Google API anahtarları, access/secret key, JWT private key, session secret, Cloudflare tunnel token, tam e-posta adresleri ve kimlik doküman verisi bulunmaz.
- AWS hesap kimlikleri, repo URL'si, DNS, full Cloudflare tenant identifier ve secret ARN'ler Azure AI için gerekli olmadığından maskelenmiştir.
- Kod/altyapı durumları konuşma ve gözlemlenen deployment sonuçlarına dayanır; veri gerçekliği için repo/AWS/GitHub read-only doğrulama zorunludur.
- Bu belgedeki planlanan özellikler 'yapılmış' sayılmaz. Her feature için güvenlik, test ve kullanıcı deneyimi kabul kriterleri yeniden uygulanmalıdır.

Belge sonu - TurkSquare teknik handover